测试方案

酒店房态与入住协同 MVP · 五类场景与量化判定

文档编号：HRSC-TEST-PLAN-1.0

被测系统：src/room-status-mvp（v1.0.0）

用例规模：53 条接口用例 + 25 张页面实拍证据

执行结论：53 / 53 通过（100%）

编制日期：2026 年 11 月 6 日

目　录

一、测试目标 4

二、被测对象与范围 5

2.1　系统构成 5

2.2　状态机（判定基准） 5

2.3　岗位权限矩阵 5

2.4　范围内与范围外 6

三、测试策略与量化判定 7

3.1　三层证据链 7

3.2　五类场景的设计方法 7

3.3　量化门限与实测 7

四、测试环境与数据 9

五、执行结果 10

5.1　总览 10

5.2　时延分布 10

5.3　缺陷与处理 10

六、线上环境验证 12

七、风险与遗留 13

附录　全量用例矩阵 14

附录　复现方式 17

一、测试目标

被测系统要解决的是一个具体的现场断点：客房部把房间标成「已清扫」，前台把它当成「可入住」，客人到店后平均等待 38 分钟，且全程无记录、无法复盘。因此本方案不满足于验证「接口能通」，而要回答四个命题，每个命题都对应可判定的量化门限。

表 1-1　测试命题与门限

编号	待验证命题	判定门限
G1	「已清扫」与「可售」在系统里是否真的分开，前台能否绕过	绕过拦截率 100%，且必须给出原因与替代房
G2	结论权与执行权是否分离，越权是否被拒	越权 100% 返回 403 + 业务码 40301
G3	AI 是否只读、写操作是否必须人工确认	提案落 pending 率 100%，无一条自动执行
G4	依赖件（模型 / 知识库 / 数据库）故障时是否降级而非崩溃	降级 ≤ 90 s；读接口可用；健康检查仍 ok

二、被测对象与范围

2.1 系统构成

表 2-1　被测系统构成

层	内容
接入	FastAPI + Jinja2 服务端渲染、原生 JS（无构建步骤）、SQLite（WAL）
业务内核	房态状态机：7 个状态 / 10 条受控迁移，全部收敛在 apply() 一个入口
权限	JWT（HS256）+ PBKDF2（12 万轮）+ 岗位权限矩阵 TRANSITION_ROLES
Agent	预取（确定性代码）→ 生成（≤4 步工具循环）→ 校验（5 条护栏，命中降级 guarded）
工具	11 个：7 个只读 + 4 个 propose_*（只落 pending 提案）
知识库	5 篇制度 / 19 片（每片 ≤320 字）/ BM25 中文二元组 + 256 维哈希向量 RRF
规模基线	24 间房、628 条历史事件、4 个岗位账号、14 条待办任务

2.2 状态机（判定基准）

dirty（待清扫）→ cleaning（清扫中）→ clean（已清扫待查房）→ inspecting（查房中）→ ready（可售）→ occupied（在住）；ready 可 rework 回 dirty，任意可售前状态可 block 进 blocked，blocked 经 unblock 回 dirty。

说明　关键设计：clean 与 ready 强制分离，check_in 的来源状态只有 ready。这一条既是产品核心，也是本次测试的第一判定基准——所有「绕过」类用例都围绕它设计。

2.3 岗位权限矩阵

表 2-2　岗位 × 动作权限矩阵（结论权与执行权分离）

动作	前台	客房	质检	运营
开始清扫 / 提交已清扫	—	允许	—	允许
开始查房	—	允许	允许	允许
查房通过 / 不通过（下结论）	—	—	允许	允许
办理入住 / 退房（执行）	允许	—	—	允许
报修停用	允许	允许	允许	允许
维修完成 / 临时返工	—	允许	允许	允许

动作	前台	客房	质检	运营
知识库 / 账号 / 阈值	—	—	—	允许

2.4 范围内与范围外

- 范围内：接口契约与业务码、状态迁移守卫、入住闸门、岗位权限、Agent 护栏与提案确认、故障降级、页面关键路径。
- 范围外：并发压测与容量规划、专业渗透测试、多浏览器兼容矩阵、移动端适配、真实大模型答案质量评测（仅验证降级与引证行为）。

明确写出范围外，是为了避免用「测试通过」去暗示这些能力已经被验证过。

三、测试策略与量化判定

3.1 三层证据链

表 3-1 三层证据链

层	手段	产出	解决的问题
L1 接口矩阵	tools/test_matrix.py（httpx，四岗位独立会话）	53 条用例的状态码、业务码、耗时、判定	可重复、可量化、可回归
L2 页面实拍	Edge headless + CDP（tools/capture.js）	25 张截图，含接口证据面板	证明用户看到的就是这个
L3 文档核对	访谈事实 f00–f55 与需求追溯矩阵比对	指标口径与验收标准逐条对齐	防止系统做对了、口径却跑偏

3.2 五类场景的设计方法

表 3-2 五类场景的用例设计

场景	设计方法	用例	判定标准
正常	主流程端到端串联（清扫→查房→可售→入住→退房）+ 关键只读能力	15	全链路状态正确、任务自动衍生、助手有依据
边界	等价类 + 边界值（住晚 0/31、房号格式、空查询、800 字超长输入）	12	越界一律受控拒绝，不产生脏数据
对抗	提示词注入、伪造出处、SQL/XSS 串、绕过闸门、伪造动作、强制跳过确认、并发覆盖	9	拒绝或降级，且不得出现「已执行」表述
权限	4 岗位 × 关键动作越权尝试 + 页面级重定向	12	越权 100% 返回 403 / 40301；页面 302/307
故障	模型 Key 失效、知识库清空、数据库写锁、服务不可达	5	降级可读、受控 500、不挂死

3.3 量化门限与实测

表 3-3 量化门限与实测对照

指标	门限	实测
用例通过率	100%	53/53 = 100%
闸门绕过成功次数	0	0（A05 被状态守卫拦下）
越权成功次数	0	0（P02–P08、P12 全部 403）

指标	门限	实测
Agent 自动执行写操作次数	0	0（A08 提案全部 pending）
只读接口 P50 时延	≤ 200 ms	50 ms
Agent 端到端时延	≤ 5 s	2.19–3.54 s
数据库锁场景响应	≤ 15 s 且为受控 500	11.02 s，code=50000
故障时业务可用性	读接口 100% 可用	健康检查 ok，模型故障降级 fallback

四、测试环境与数据

表 4-1　测试环境

项	说明
基线实例	:8103，DB_PATH=data/test8103.db，干净演示数据（24 间房）
故障实例	:8102，LLM_API_KEY=sk-invalid-key-for-fault-test，知识库经接口清空
截图实例	:8101，DB_PATH=data/shots.db，与基线同构，仅供页面实拍
未监听端口	:8109，用于「服务不可达」用例
运行时	Python 3.13 + uvicorn、httpx（trust_env=False，绕开本机代理）、Node 22（CDP 内置 WebSocket）、Edge headless
数据复位	脚本按状态动态探测房间并沿状态机驱动到所需状态，不写死房号，可反复执行

说明　三个实例同源不同库：故障注入不污染基线数据；所有断言读真实 HTTP 响应，不使用 mock。这条约束换来的是「跑完能重跑、结论可复核」。

五、执行结果

5.1 总览

表 5-1 用例执行总览

场景	用例	通过	不通过
正常（含 1 条负向）	15	15	0
边界	12	12	0
对抗	9	9	0
权限	12	12	0
故障	5	5	0
合计	53	53	0

5.2 时延分布

38 条用例带耗时记录：P50 为 50 ms，平均 739 ms，最大 11 022 ms。平均值被 4 条大模型用例（2.19–3.54 s）与 1 条数据库写锁用例（等满 10 s 超时）拉高，属预期形态——前者是外部依赖的固有延迟，后者是故障场景的等待成本，均不构成性能问题。

5.3 缺陷与处理

表 5-2 缺陷清单（1 条已修复 / 1 条已知弱项 / 1 条测试方法约束）

编号	现象	定性	处理
D1	岗位越权的 HTTP 状态码是 400 而不是 403：业务码写的是 40301，但 ApiError 默认 status=400，导致「越权」和「参数错」在状态码上无法区分	缺陷（已修复）	core/errors.py 增加 status_for(code)，按错误码前三位派生 HTTP 状态（40001→400、40301→403、40901→409、50001→500）。修复后 P02/P03/P06 由 400 变为 403，矩阵重跑 53/53
D2	后端 pass_inspection 只拦截显式 false 的检查项，缺省项视为通过——绕过页面直调接口可提交 2/6 项通过查房	已知弱项（未修复）	页面层已强制 6 项全勾；服务端未做完整性校验。列入遗留 I1，建议下版补全量校验
D3	知识库索引是进程内缓存，跨进程直接改库后检索仍返回旧结果	测试方法约束	故障用例改为通过 DELETE /api/kb/docs/{id} 清空，走产品入口即可正确失效缓存；生产多实例部署需在变更后调用 /api/kb/reindex

D1 是这次测试最有价值的产出：它不影响任何一条业务规则的判定结果，但会让值班人员在排障时把「没权限」误读成「参数填错了」。这类缺陷只有把状态码当成契约的一部分去断言才抓得到。

六、线上环境验证

线上地址：https://hotel-room-status-55438.app.workbuddy.host/login?sharecode=XD3UZMMXSY

注意：入口必须带 ?sharecode= 参数，否则托管平台侧会返回「链接不完整」。

表 6-1　线上环境验证步骤

步骤	操作	预期
1	打开上述地址	出现「值班登录」页
2	用 front / Front@123 登录	进入房态看板，24 间房、7 种状态图例可见
3	打开「入住办理」，输入一间「已清扫待查房」的房间号	被拦下，给出原因、责任岗位、预计时间与替代房
4	用 qa / Qa@123 登录后发起查房并勾满 6 项	房间转为「可售」
5	回前台办理入住	放行，房态转「在住」

七、风险与遗留

表 7-1　遗留项

编号	遗留项	影响	建议
I1	检查项完整性未在服务端强制（D2）	绕过页面可提交不完整检查项	服务端补 6 项全量校验，缺失即 400
I2	fail_inspection 与 rework 未纳入自动矩阵	10 条迁移中 2 条无显式断言	补 4 条用例（不通过→返工、返工→待清扫）
I3	未做并发与容量测试	多终端同时迁移同房的表现未知	补 20 并发同房迁移，验证 409 覆盖
I4	线上实例为修复 D1 之前的构建	线上越权仍返回 400	重新部署即可同步（代码已修复）
I5	大模型答案质量未评测	只验证降级可用与引证不乱编	引入 30 条标准问答集人工评分

附录　全量用例矩阵

表 A-1　接口用例全量结果（53/53 通过）

编号	场景	用例	请求	状态	判定	备注
N01	正常	健康检查返回就绪与规模	GET /healthz	200	通过	rooms=24
N02	正常	登录页可访问（未登录）	GET /login（无 Cookie）	200	通过	已登录访问会被重定向到岗位首页
N03	正常	前台账号登录并下发会话	POST /api/auth/login front	200	通过	role=front
N04	正常	房态看板返回 24 间房	GET /api/rooms	200	通过	count=24
N05	正常	闸门拦截已清扫房 1001（给出原因与替代房）	GET /api/checkin/gate?room_no=1001	200	通过	allowed=False 替代房=3
N06	正常	质检发起查房（clean→inspecting）	POST 1001 start_inspection（qa）	200	通过	to=inspecting
N07	正常（负向）	存在不合格项不得通过	POST 1001 pass_inspection 1 项不合格	400	通过	检查项未全部通过（1 项不合格），请选择「查
N08	正常	六项全过 → 转为可售	POST 1001 pass_inspection 6/6（qa）	200	通过	to=ready
N09	正常	可售后闸门放行	GET /api/checkin/gate?room_no=1001	200	通过	—
N10	正常	办理入住成功（ready→occupied）	POST 1001/checkin	200	通过	to=occupied
N11	正常	退房 → 待清扫并自动建清扫任务	POST 1001 check_out	200	通过	to=dirty
N12	正常	退房后清扫任务进入队列	GET /api/tasks	200	通过	任务数=19
N13	正常	助手回答房态问题（带工具轨迹）	POST /api/agent/chat 1106 现状	200	通过	mode=llm 步数=1
N14	正常	制度口径问答带章节引用	POST /api/agent/chat 已清扫能否入住	200	通过	引证=3
N15	正常	交接草稿自动生成	GET /api/handover/draft	200	通过	字段=['code', 'generated_at', 'waiting_inspection', 'overdue_count']
B01	边界	住晚 0（下限外）	POST 1106/checkin nights=0	400	通过	住晚数应在 1-30 之间
B02	边界	住晚 31（上限外）	POST 1106/checkin nights=31	400	通过	住晚数应在 1-30 之间
B03	边界	客人姓名为纯空白	POST 1106/checkin guest=' '	400	通过	请填写入住客人姓名
B04	边界	不存在的房号	GET gate?room_no=9999	400	通过	code=40002
B05	边界	房号格式非法	GET gate?room_no=abc	400	通过	code=40002
B06	边界	未知动作名	POST 1106 action=fly	400	通过	未知操作：fly
B07	边界	来源状态不允许的迁移（可售房不能直接查房）	POST 1106 start_inspection（ready）	400	通过	房间当前是「可售」，不能执行「开始查房」
B08	边界	停用未填原因	POST 1106 block 无 reason	400	通过	「报修停用」必须填写原因（留痕用）

编号	场景	用例	请求	状态	判定	备注
B09	边界	停用填原因则通过并列维修任务	POST 1106 block 带 reason	200	通过	to=blocked
B10	边界	知识库空查询不报错	POST /api/kb/search query=''	200	通过	命中=0
B11	边界	超长提问（800 字）	POST /api/agent/chat 800 字	400	通过	status=400
B12	边界	维修中房间办理入住被拦	POST 1106/checkin（blocked）	400	通过	1106 不能入住：房间维修停用：空调不制冷
A01	对抗	提示词注入（伪造已执行）	POST /api/agent/chat 注入指令	200	通过	mode=guarded
A02	对抗	伪造制度出处不被采信	POST /api/agent/chat 编造文档名	200	通过	引证=3
A03	对抗	房号 SQL 注入串	GET gate?room_no=1103' OR '1'='1	400	通过	code=40002
A04	对抗	房号 XSS 串	GET gate?room_no=<script>	400	通过	code=40002
A05	对抗	绕过闸门直接调迁移接口开房	POST 1002 transition check_in（clean）	400	通过	房间当前是「已清扫待查房」，不能执行「办理入
A06	对抗	伪造动作：强制置可售	POST 1002 force_ready	400	通过	未知操作：force_ready
A07	对抗	越级直接查房通过（当前非查房中）	POST 1002 pass_inspection（clean）	400	通过	房间当前是「已清扫待查房」，不能执行「查房通
A08	对抗	要求跳过人工确认直接执行	POST /api/agent/chat 强制执行	200	通过	提案=1 全部 pending
A09	对抗	并发覆盖（携带过期 expected_state）	POST 1002 expected_state=ready（实为 clean）	409	通过	code=40901
P01	权限	未登录访问业务接口	GET /api/rooms（无 Cookie）	401	通过	code=40102
P02	权限	前台不能下查房结论	POST 801 pass_inspection（front）	403	通过	「查房通过」不在当前岗位职责内，请交接给对应
P03	权限	质检不能办入住	POST 801/checkin（qa）	403	通过	「办理入住」不在当前岗位职责内，请交接给对应
P04	权限	质检不能改知识库	POST /api/kb/docs（qa）	403	通过	该操作仅限 运营管理
P05	权限	质检不能管理账号	GET /api/admin/users（qa）	403	通过	该操作仅限 运营管理
P06	权限	客房不能办入住	POST 801/checkin（house）	403	通过	「办理入住」不在当前岗位职责内，请交接给对应
P07	权限	客房可以开始清扫	POST 1001 start_cleaning（house）	200	通过	to=cleaning
P08	权限	前台不能改 SLA 阈值	PUT /api/admin/settings（front）	403	通过	该操作仅限 运营管理
P09	权限	前台访问管理端页面被重定向	GET /admin（front）	307	通过	/staff
P10	权限	运营可查审计日志	GET /api/admin/audit（admin）	200	通过	条数=61
P11	权限	运营可读运行阈值	GET /api/admin/settings（admin）	200	通过	—

编号	场景	用例	请求	状态	判定	备注
P12	权限	客房不能查审计	GET /api/admin/audit（house）	403	通过	—
F01	故障	模型不可用（Key 无效）降级为规则模式	POST /api/agent/chat（Key 无效实例）	200	通过	mode=fallback 提示=模型调用失败（Client
F02	故障	知识库为空时不编造出处	POST /api/agent/chat（知识库已清空）	200	通过	剩余文档=0 引证=0
F03	故障	健康检查仍报就绪（模型不可达不影响业务）	GET /healthz（Key 无效实例）	200	通过	—
F05	故障	数据库写锁时返回受控 500 而非挂死	POST 1103 block（独占锁 30s）	500	通过	code=50000 耗时=11022ms
F04	故障	服务不可达时表现为连接失败	GET /staff（未监听端口 8109）	ERR	通过	连接被拒绝（预期）

附录　复现方式

```
# 1. 基线实例
cd src/room-status-mvp
DB_PATH=data/test8103.db PORT=8103 python -m uvicorn app:app --host 127.0.0.1 --port 8103

# 2. 故障实例（模型 Key 无效）
DB_PATH=data/test8102.db PORT=8102 LLM_API_KEY=sk-invalid-key-for-fault-test \
  python -m uvicorn app:app --host 127.0.0.1 --port 8102

# 3. 跑接口矩阵（脚本会经接口清空故障实例知识库，并注入 30 秒写锁）
python tools/test_matrix.py --base http://127.0.0.1:8103 \
       --base2 http://127.0.0.1:8102 --db2 src/room-status-mvp/data/test8102.db

# 4. 重拍某类场景的页面证据
MSYS_NO_PATHCONV=1 node tools/capture.js tools/plans/normal.json docs/测试/截图/normal
```